

1) RISK IDENTIFICATION AND ITS COMPONENTS

- * IT professionals to know their organization's information assets through identifying classifying and prioritizing them.

- * Assets are the targets of various threats and threat Agents and the goal is to protect the assets from the threats.

- * Once the organizational assets have been identified, a threat identification process is undertaken.

- * The circumstances and settings of each information asset are examined to identify vulnerabilities.

- * The process of Risk Identification begins with the identification of the organization's information assets and an assessment of their value.

Asset Identification & valuation

- * Includes all the elements of an organization's system, such as people, procedures, data and information, software, hardware and networking elements.

- * Then, you classify and categorize the assets, adding details.

- * When vulnerabilities are found, controls are identified and assessed as to their capability to limit possible losses in the eventuality of attack.

Plan and organize
the process

Risk
Identification

categories systems
components

Inventory and
Category assets

Identify Threats

Specify
vulnerable assets

Assign value
to attack
on assets

Risk
Assessment

assets likelihood
of attack on
vulnerabilities

Calculate relative
Risk factor for
assets

Review
possible controls

Document Finding

Components of Risk Identification.

* people include employees and nonemployees. There are two categories of employees. those who hold trusted roles and have correspondingly greater authority and accountability and other staff who have assignments without special privileges.

* Procedures fall into two categories: IT and business standard procedures, and IT and business sensitive procedures. The business sensitive procedures are those that may assist a threat agent in crafting an attack ~~the~~ against an organization or that have some other content or feature that may introduce risk of the organization.

* Data components have been expanded to account for the management of information in all stages. Transmission, processing and storage.

* Software components can be assigned to one of three categories: Applications, operating system, or security components.

* Hardware is assigned to one of two categories: the usual systems devices and their peripherals. People, Procedure & Data Asset Identification.

* people: position name Number/ID: Supervisor
Security clearance level; special skills.

* Procedures: Description / intended purpose / hardware and networking elements, storage location for update, storage location for reference.

* Data: classification; owner: creator, manager, size of data structure; data structure used: online/offline / backup procedure employed.

Hardware, Software and Network Asset Identification

* Name: should adopt naming standards that do not convey information to potential system attackers.

* IP Addresses : Usefull for Network devices & Servers.
* Media Access control (MAC) address : Electrical Serial numbers and hardware Addresses. All network interfall hardware devices have a unique number.

2) RISK CONTROL STRATEGIES

Four basic strategies to control each of the risks that result from these vulnerabilities.

- 1) Apply safeguards that eliminate the remaining uncontrolled risks for the vulnerability.
- 2) Transfer the risk to other areas (OS) to outside entities.
- 3) Reduce the impact should the vulnerability be exploited.
- 4) Understand the consequences and accept the risk without control or mitigation.

Avoidance :

It is the risk control strategy that attempts to prevent the exploitations of the vulnerability, and is accomplished by means of

- * Countering threats
- * Removing vulnerabilities in assets
- * Limiting access to assets
- * Adding protective safeguards.

Three common methods of risk Avoidance are

- *) Application of policy
- *) Application of Training & Education
- *) Application of Technology.

Transference:

* Transference is the control approach that attempts to shift the risk to other assets, other processes, or other organizations.

* It may be accomplished through rethinking how services are offered, revising deployment models, outsourcing to other organizations, purchasing insurance.

Mitigation

* It is the control approach that attempts to reduce the impact caused by the exploitation of vulnerability through planning & preparation.

* Mitigation begins with the early detection that an attack is in progress and the ability of the organization to respond quickly, efficiently and effectively.

* Include 3 types of plans.

* Incident Response plan (IRP) - Actions to take while incident is in progress.

* Disaster recovery plan (DRP) - Most common mitigation procedure.

* Business continuity plan (BCP) - continuation of business activities if catastrophic event occurs.

* Incident Response plan:

This IRP plan provides answers to questions such as,

1. What do I do now?
2. What should the administrator do first?
3. Whom should they contact?
4. What should they document?

The IRP also enables the organizations to take coordinated action that is either predefined and specific or ad hoc and reactive.

* Disaster Recovery plan (DRP)

- * can include strategies to limit losses before and during the disaster.

- * DRP focuses more on preparations completed before and actions taken after the incident, whereas the IRP focuses on intelligence gathering, information analysis and urgent.

* Business Continuity plan (BCP)

- * BCP is the most strategic and long term of the three plans.

- * It encompasses the continuation of business activities if a catastrophic event occurs, such as the loss of an entire database, building or operations centre.

- * The BCP includes planning the steps necessary to ensure the continuation of the organisation when the scope or scale of disaster exceeds the ability of the DRP to restore operations.

- * Many companies offer this service as a contingency against disastrous event such as fires.

Acceptance:

- * It is the choice of do nothing to protect a vulnerability and do accept the outcome of exploitation.

- * This strategy occurs when the organization has:

- * Determined the level of risk

- * Assessed the probability of attack

- * Performed thorough cost benefit analysis.